

Universidad Nacional Autónoma de México



Facultad de Ingeniería

Alumno:

Lara Hernandez Angel Husiel - 320060829

Lugo Manzano Rodrigo - 320206968

Flores Colin Victor Jaziel - 320266083

Garcia Cortes Adolfo de Jesus - 320317264

Seguridad informatica basica

Semestre: 2027-1

Actividad 6

Registro de riesgos

Fecha de Entrega:

31 de Octubre del 2026

1 Plantilla y Registro de Riesgos de VELOX Automotriz S.A. de C.V.

1.1 Tabla de Escenarios de Riesgo (Formulación Dual: Forma 1 y Forma 2)

#	ID	Nombre del Riesgo	Escenario — Forma 1 (Orientado al Impacto y Proceso Operativo)	Escenario — Forma 2 (Orientado al Adversario y Activo Comprometido)
1	RSK-01	Paro de línea robotizada en planta por ataque a MES/PLC	Un ciberataque altera los parámetros de control industrial y cifra la trazabilidad de manufactura, provocando el paro total de las líneas de ensamblaje en la planta de Guanajuato.	Un adversario de ransomware (*Gengar/Akira*) compromete el servidor FactoryTalk MES y los PLCs Allen-Bradley que gestionan los controles de los robots de ensamblaje (CVE-2022-44725, CVE-2023-3595).
2	RSK-02	Exposición de ubicación GPS y telemetría en la nube	Una brecha en el almacenamiento en la nube expone públicamente las coordenadas GPS históricas y datos personales de los conductores de vehículos eléctricos VELOX.	Un actor de amenaza accede sin autorización o explota los buckets de AWS S3 y la base de datos MongoDB Atlas que gestionan los registros de telemetría vehicular (CVE-2024-7646).
3	RSK-03	Exfiltración de propiedad intelectual ADAS y VCU	Un ciberataque sustrae y filtra los diseños confidenciales de baterías, algoritmos ADAS y código fuente de la VCU, causando pérdida de ventaja competitiva e incumplimiento con socios Tier 1.	Un adversario avanzado (*Mewtwo/APT41* o *BlackCat*) compromete el servidor Atlassian Confluence y las estaciones de ingeniería que gestionan la documentación técnica (CVE-2023-22518).
4	RSK-04	Secuestro remoto de comandos de la flota vehicular	Un ciberataque envía órdenes remotas no autorizadas para desbloquear puertas, encender motores o inmovilizar vehículos de clientes en circulación para exigir un rescate o robar unidades.	Un adversario compromete la API de autenticación JWT y el servidor Node.js del portal connect.veloxauto.mx que gestionan el envío de comandos remotos a los vehículos (CVE-2022-21449).
5	RSK-05	Secuestro del dominio corporativo y cifrado del ERP SAP	Un ataque de ransomware cifra las finanzas, nómina y pedidos de autopartes Just-in-Time, paralizando la administración y el abastecimiento de insumos de VELOX Automotriz.	Un adversario compromete la VPN perimetral FortiGate 600F, el Active Directory y el servidor ERP SAP S/4HANA que gestionan los accesos y recursos empresariales (CVE-2024-21762, CVE-2022-22536).

1.2 Continuación de la Tabla de Escenarios de Riesgo

#	ID	Nombre del Riesgo	Escenario — Forma 1 (Orientado al Impacto y Proceso Operativo)	Escenario — Forma 2 (Orientado al Adversario y Activo Comprometido)
6	RSK-06	Interrupción operativa de la red de concesionarios	Un ciberataque inhabilita el sistema de ventas, inventario de refacciones y citas de taller en los 12 estados de la República, deteniendo la comercialización de vehículos.	Un adversario compromete el servidor web de aplicaciones Apache Tomcat 10 (dealer.veloxauto.mx) que gestiona el portal comercial de concesionarios (CVE-2025-24813).
7	RSK-07	Filtración de datos personales vía sistema de tickets ITSM	Una intrusión en el sistema de gestión de tickets filtra expedientes de soporte, datos personales (PII) y números VIN de clientes, derivando en extorsión financiera contra la empresa.	Un Actor de Amenaza (TA) compromete la plataforma de tickets ServiceNow y el servidor de BD PostgreSQL 17 que gestionan datos personales mediante la explotación de 2 vulnerabilidades (CVE-2024-4879 y CVE-2024-10978).
8	RSK-08	Inyección masiva de firmware malicioso vía OTA	Una actualización de software adulterada se distribuye de forma remota a toda la flota de vehículos VELOX, corrompiendo el control de energía e inutilizando las unidades.	Un adversario compromete el Servidor OTA (ota.velox.internal) y la PKI Interna / HashiCorp Vault que gestionan la firma criptográfica y despliegue de actualizaciones (CVE-2024-2048, CVE-2021-32804).
9	RSK-09	Manipulación intravehicular de VCU y sensores ADAS	Un ataque electrónico desactiva la asistencia de frenado y dirección autónoma durante la conducción, generando riesgo de accidente severo para los ocupantes del vehículo.	Un adversario compromete la unidad IVI Snapdragon, el Gateway OBD-II y el kernel QNX RTOS de la VCU que gestionan el bus CAN FD y los controles críticos (CVE-2021-22156, CVE-2024-33066).
10	RSK-10	Indisponibilidad del portal web y telemetría por DDoS	Un ataque masivo de saturación deja fuera de servicio el portal de cotizaciones y colapsa la recepción de datos de sensores IoT de planta y de la flota conectada.	Un adversario hacktivista (*Electrode/KillNet*) compromete la disponibilidad del servidor Nginx público y del broker Eclipse Mosquitto MQTT que gestionan el tráfico web y las colas de telemetría (CVE-2023-28366).

1.3 Plantilla Completa del Registro de Riesgos (Tema 5)

#	ID del riesgo	Nombre del riesgo	Propietario del riesgo	Nivel de Riesgo	Respuesta al riesgo	Estado del plan de acción	Última evaluación
1	RSK-01	Paro de línea robotizada en planta por ataque a MES/PLC	Director de Planta OT e Ingeniería Industrial	Crítico	Mitigar (Segmentación IT/OT + Parcheo PLC/OPC-UA) y Transferir (Póliza Cyber-OT)	En implementación (75% completado)	25/Ago/2026
2	RSK-02	Exposición de ubicación GPS y telemetría en la nube	Arquitecto Líder de Nube (Cloud Security) y DPO	Crítico	Mitigar (Bloqueo público S3, cifrado KMS y CSPM continuo)	Implementado / En monitoreo continuo	26/Ago/2026
3	RSK-03	Exfiltración de propiedad intelectual ADAS y VCU	Director de I+D Automotriz y CISO	Alto	Mitigar (Parcheo Confluence, DLP, Zero Trust en estaciones de ingeniería)	En progreso (60% completado)	24/Ago/2026
4	RSK-04	Secuestro remoto de comandos de la flota vehicular	Gerente de Plataforma Conectada (*VELOX Connect*)	Crítico	Mitigar (Actualización JWT/Bouncy Castle, MFA biométrico en comandos críticos)	En implementación urgente (85%)	27/Ago/2026
5	RSK-05	Secuestro del dominio corporativo y cifrado del ERP SAP	Director de TI Corporativa y CISO	Crítico	Mitigar (Parcheo FortiOS/SAP, MFA FIDO2, Backups inmutables) y Transferir (Seguro)	En implementación (80% completado)	28/Ago/2026
6	RSK-06	Interrupción operativa de la red de concesionarios	Gerente de Sistemas Comerciales y Red de Concesionarios	Alto	Mitigar (Actualización Tomcat 10.1.35+, WAF y deshabilitar Partial PUT)	En progreso (65% completado)	25/Ago/2026
7	RSK-07	Filtración de datos personales vía sistema de tickets ITSM	Subdirector de Soporte TI (ITSM) y Oficial de Privacidad	Alto	Mitigar (Parche ServiceNow HF-2024-06, auditoría PostgreSQL y acceso solo por VPN)	Implementado / En validación Red Team	27/Ago/2026
8	RSK-08	Inyección masiva de firmware malicioso vía OTA	Líder de Criptografía (PKI) y Arquitectura OTA	Crítico	Mitigar (HSM físico para claves raíz, doble firma código OTA y parche Vault)	En progreso (70% completado)	28/Ago/2026
9	RSK-09	Manipulación intravehicular de VCU y sensores ADAS	Gerente de Ingeniería Embebida y Seguridad Funcional	Crítico	Mitigar (Parche QNX BadAlloc, Firewall en Gateway OBD-II, SecOC) y Evitar (Prohibir dongles aftermarket)	Planificado / En pruebas de banco HIL	29/Ago/2026
10	RSK-10	Indisponibilidad del portal web y telemetría por DDoS	Gerente de Infraestructura de Red y Telecomunicaciones	Medio	Mitigar (AWS Shield Advanced, Rate Limiting y actualización Mosquitto MQTT) y Aceptar (Riesgo residual de latencia)	Implementado / Monitoreo SOC 24/7	29/Ago/2026

2 Caso General del grupo Groq

#	ID	Nombre del Riesgo	Escenario — Forma 1 (Orientado al Impacto y Proceso Operativo)	Escenario — Forma 2 (Orientado al Actor / Adversario y Activo Comprometido)
7	RK-007	ShadowAI (Uso no autorizado de Groq, Claude, DeepSeek y navegadores con IA)	Un empleado utiliza en sus operaciones del día a día la IA de Groq, Claude, DeepSeek o navegadores con servicios de IA integrados sin autorización corporativa, provocando la filtración de código fuente automotriz, secretos de red y datos personales de clientes en servidores externos.	Un actor interno (*Ditto*) o adversario externo que intercepta sesiones de terceros compromete la confidencialidad de las estaciones de ingeniería, Confluence, ServiceNow y el código del portal corporativo al procesar datos confidenciales en plataformas externas de IA (CWE-200, OWASP LLM06).
7.1	RK-007a	ShadowAI — Groq (Depuración de código y firmware en GroqCloud)	Un ingeniero pega bloques de código propietario de la ECU Principal (VCU) y microservicios Node.js en la plataforma de inferencia rápida Groq para resolver fallos del día a día, exponiendo algoritmos de control vehicular y llaves API de AWS/Vault.	Un colaborador con privilegios de desarrollo compromete la confidencialidad del repositorio de firmware Renesas RH850, los microservicios del portal corporativo y los secretos de HashiCorp Vault al enviarlos a los servidores externos de Groq.
7.2	RK-007b	ShadowAI — Claude (Resumen de tickets ITSM y documentos ERP)	Un analista operativo sube reportes de incidentes, contratos de proveedores Tier 1 y bases de clientes en sesiones personales de Claude para agilizar la redacción de informes diarios, filtrando datos personales (PII) y números VIN.	Un usuario corporativo compromete los registros confidenciales extraídos de ServiceNow, Atlassian Confluence y SAP S/4HANA al almacenarlos en el historial de contexto de servidores externos de Anthropic Claude.
7.3	RK-007c	ShadowAI — DeepSeek y Navegador IA (Asistentes web y lectura DOM)	Un empleado utiliza un navegador con servicios de IA integrados o consulta a DeepSeek durante sus labores diarias, permitiendo que el asistente capture pantallas activas, logs de seguridad y diseños ADAS, enviándolos a nubes en jurisdicciones externas.	Un navegador o extensión de IA no autorizada compromete las sesiones web activas en las laptops corporativas (portales internos de ERP y SIEM, y diseños NVIDIA Drive Orin) al transmitir el contenido del DOM a servidores de DeepSeek y terceros.

2.0.1 Plantilla Oficial del Registro de Riesgos para RK-007

#	ID del riesgo	Nombre del riesgo	Propietario del riesgo	Nivel de Riesgo	Respuesta al riesgo	Estado del plan de acción	Última evaluación
7	RK-007	ShadowAI (Uso de Groq, Claude, DeepSeek y navegadores IA en operaciones diarias)	CISO, Oficial de Privacidad (DPO) y Director de Ingeniería de Software	Alto	Mitigar (DLP en endpoints, CASB en FortiGate, despliegue de IA privada en AWS Bedrock) y Evitar (Bloqueo de navegadores/extensiones IA no autorizados y dominios sin acuerdo TISAX)	En implementación (70% completado: reglas DLP y política GPO activas)	29/Ago/2026

Referencias

Myles, P. (2026). *AI doubled auto industry cyberattacks: Upstream 2026 Global Automotive and Smart Mobility Cybersecurity Report*. WardsAuto. https://www.wardsauto.com/news/ai-doubles-automotive-cyber-attack 813455/

National Institute of Standards and Technology. (2012). *Guide for Conducting Risk Assessments (NIST SP 800-30 Rev. 1)*. NIST. https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf

National Institute of Standards and Technology. (2023). *Guide to Industrial Control Systems (ICS) Security — NIST SP 800-82 Rev. 3*. NIST. https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-82r3.pdf

National Institute of Standards and Technology. (2024). *National Vulnerability Database (NVD)*. NIST. https://nvd.nist.gov/

Rockwell Automation. (2023). *Security Advisory SD1699: Remote Code Execution Vulnerabilities in ControlLogix Communications Modules*. Rockwell Automation. https://www.rockwellautomation.com/en-us/support/advisory.SD1699.html

SAE International. (2021). *ISO/SAE 21434: Road Vehicles — Cybersecurity Engineering*. SAE International. https://www.sae.org/standards/content/iso_sae21434/

Soo, Z. (2023). *Toyota Says Data of 2.15 Million Customers in Japan Exposed for 10 Years*. Reuters. https://www.reuters.com/business/autos-transportation/toyota-says-data-21-million-customers-may-have-been-

The Record by Recorded Future. (2023). *Akira Ransomware Attack on Yanfeng Disrupted Stellantis Production Lines*. Recorded Future News. https://therecord.media/akira-ransomware-yanfeng-automotive-stellantis

Toulas, B. (2023). *Yanfeng Automotive Interiors Hit by Akira Ransomware*. BleepingComputer. https://www.bleepingcomputer.com/news/security/akira-ransomware-hit-yanfeng-automotive-interiors-caused-stella

Toulas, B. (2024). *Hyundai Motor Europe Hit by Black Basta Ransomware Attack*. BleepingComputer. https://www.bleepingcomputer.com/news/security/hyundai-motor-europe-hit-by-black-basta-ransomware-attack

Toyota Motor Corporation. (2023). *Notice Regarding Vehicle Data Stored in a Cloud Environment*. Toyota Motor Corporation. https://global.toyota/en/newsroom/corporate/39285947.html

Upstream Security. (2024). *Global Automotive Cybersecurity Report 2024*. Upstream Security. https://upstream.auto/reports/global-automotive-cybersecurity-report/

Wilhoit, K., & Hilt, S. (2023). *Driving Security Into Connected Cars: Threat Model and Recommendations*. Trend Micro Research. https://www.trendmicro.com/vinfo/us/security/news/internet-of-things/driving-security-into-connected-cars-threat-model-and-recommendations